MDM GRC READINESS & CONTROL ASSURANCE CASE STUDY

MDM-D14

Executive Readiness Report

Deliverable 14 of 15 in a portfolio case study on readiness and control assurance for mobile access to Microsoft 365 at a fictional 850-employee Saudi financing company. Cross-references to other deliverables use their MDM-D numbers.

Prepared by
Ali Fathi Aldhabiki
Cybersecurity Governance, Risk & Compliance (GRC)
linkedin.com/in/ali-aldhabiki-a74354212 | ali.f.aldhabiki@outlook.com

Notice
The organization is fictional. No Microsoft Intune or Entra ID tenant was configured; all evidence, test results and ratings are simulated.

Executive Readiness Report

MDM-D14

1. Purpose and Scope

This report tells senior management where the MDM case stands as at 16 November 2026, and what it needs from them. It answers five questions: the overall risk level, the three main gaps, the immediate action, who owns it, and the decision required from management.

It adds no new ratings, estimates or decisions. Every figure comes from MDM-D12 or MDM-D13, with the section it came from in brackets. Where this report differs from a source, the source is correct.

Two results are reported separately because they answer different questions. The risk level is the current residual risk: how exposed the organization is now, within the tested scope. The readiness status shows whether the controls can be relied on yet. The two can differ, and in this case they do.

The report is issued to senior management quarterly, as set in MDM-D13 Section 5.1. The GRC Analyst prepares it and the CISO approves it before issue, as MDM-D02 sets for readiness conclusions.

No tenant was configured. All values, dates and decisions are simulated.

Structure

Section	Content	Main Sources
1. Purpose and Scope	Purpose, scope and structure of this report	None
2. Summary for Management	One answer to each of the five questions	MDM-D12, MDM-D13
3. Risk Level and Readiness Status	The current residual risk, the readiness status, and why they differ	MDM-D12 Section 4; MDM-D13 Sections 4.1–4.2
4. Top Three Gaps	The three gaps that most affect the risk level and the readiness status, and the risk each leaves open	MDM-D11 Sections 4–5; MDM-D12 Section 4; MDM-D13 Section 4.2
5. Immediate Action and Owners	What must start now, who owns it, and when it is checked	MDM-D11 Section 5; MDM-D12 Section 5
6. Decisions Required from Management	What only senior management can decide, and what happens without a decision	MDM-D12 Section 3; MDM-D13 Sections 4.5 and 5.2

Section	Content	Main Sources
7. Outlook	What the next retests can change, what they cannot, and what would raise the risk level	MDM-D12 Section 6; MDM-D13 Sections 4.1 and 4.4
8. Basis and Limitations	What this report relies on and what it cannot show	MDM-D12 Section 7; MDM-D13 Section 6

2. Summary for Management

As at 16 November 2026, the case is Not Ready, although no assessed risk is at High. Current exposure within the tested scope is Medium, but most tested controls do not yet work as designed, so they cannot be relied on. All values are simulated.

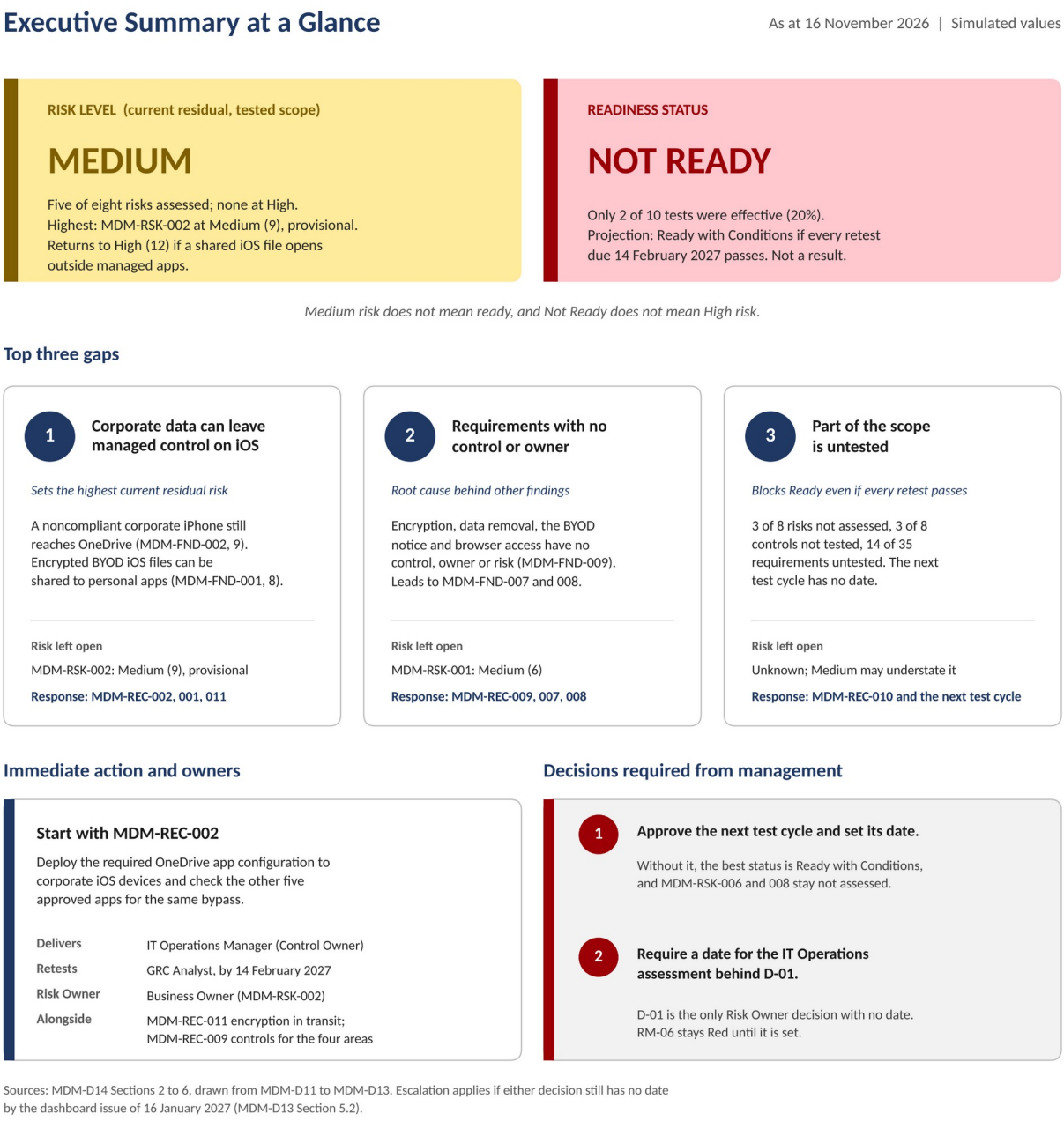


Figure 1. Executive summary at a glance. Each panel answers one of the five questions in the table below. All values are simulated.

Question	Answer	Source
1. What is the overall risk level?	Medium, within the tested scope. All five assessed risks sit at Medium. The highest is MDM-RSK-002, corporate data leakage, at Medium (9). It is provisional and returns to High	MDM-D12 Sections 4 and 6; MDM-D13 Sections 4.1–4.2

Question	Answer	Source
	(12) if a shared iOS file proves readable outside managed apps. Three of the eight risks are not assessed yet. Separately, the readiness status is Not Ready, because only 2 of 10 tests were effective (20%).	
2. What are the three main gaps?	(1) Corporate data on iOS can leave managed control: a noncompliant corporate iPhone still reaches OneDrive (MDM-FND-002, score 9), and iOS BYOD users can share encrypted files to personal apps (MDM-FND-001, score 8, accepted under D-02). (2) Encryption, data removal, the BYOD notice and browser access have no control, owner or risk (MDM-FND-009). This is the root cause behind the unconfirmed wipe of a lost device and the missing retention period. (3) Part of the scope is untested: 3 of 8 risks, 3 of 8 controls and 14 of 35 standard requirements, and the next test cycle has no date.	MDM-D12 Sections 3–4; MDM-D13 Sections 4.2 and 4.5
3. What must happen now?	Deploy the required OneDrive app configuration to corporate iOS devices, and check the other five approved apps for the same bypass (MDM-REC-002). It fixes the highest-scored finding and is first in the remediation priority. Alongside it, confirm encryption in transit (MDM-REC-011), which decides whether MDM-RSK-002 stays provisional and whether D-04 takes effect.	MDM-D11 Section 5; MDM-D12 Sections 3 and 5
4. Who is responsible?	The IT Operations Manager, as Control Owner, delivers both actions. The GRC Analyst retests them by 14 February 2027. The Business Owner owns MDM-RSK-002 as Risk Owner, and the CISO tracks progress in the monthly dashboard.	MDM-D12 Sections 3 and 5; MDM-D13 Section 5.1
5. What decision is required from management?	Approve the next test cycle and set its date. Without it, the case cannot reach Ready, even if every retest passes. Also require a date for the IT Operations assessment behind Risk Owner decision D-01, which has none.	MDM-D13 Sections 4.1, 4.4 and 4.5

Sections 3 to 6 give the basis for each answer. Section 7 shows what the retests due by 14 February 2027 can change.

3. Risk Level and Readiness Status

The risk level is Medium and the readiness status is Not Ready. Both hold at once, because they measure different things.

3.1 Risk Level

Five of the eight risks were assessed, and all five sit at Medium. The two risks that started at High, MDM-RSK-002 and MDM-RSK-005, fell to Medium. No assessed risk is at High (MDM-D12 Section 4).

Risk	Inherent	Current Residual	Target Residual
MDM-RSK-002 Corporate data leakage to personal apps or accounts	High (12)	Medium (9), provisional	Medium (8)
MDM-RSK-005 Unauthorized changes to central device security settings	High (12)	Medium (6)	Low (3)
MDM-RSK-001 Unauthorized access to data on a lost corporate device	Medium (9)	Medium (6)	Low (3)
MDM-RSK-003 Corporate data exposure through noncompliant devices	Medium (9)	Medium (6)	Medium (6) until D-01 is decided
MDM-RSK-007 Continued corporate access after contractor departure	Medium (9)	Medium (6)	Low (3)
MDM-RSK-004 Business disruption from incorrect access policy changes	Medium (6)	Not assessed	Not set
MDM-RSK-006 Inappropriate internal access to employee device reports	Medium (6)	Not assessed	Not set
MDM-RSK-008 Inaccurate device compliance reporting	Medium (6)	Not assessed	Not set

Source: MDM-D12 Section 4.

Current residual gives credit only to controls that worked when tested. Targets are what the Risk Owner expects once the open recommendations close, and they hold only after a passed retest (MDM-D12 Section 2.1).

MDM-RSK-002 is provisional until encryption in transit is confirmed (MDM-REC-011). It cannot fall below Medium (8) while the iOS Share exposure stays accepted under D-02 (MDM-D12 Section 4). Section 7 sets out what would return it to High.

Not assessed means the risk's controls were not tested. It does not mean the risk is low.

3.2 Readiness Status

The case is Not Ready because only 2 of 10 tests were effective (20%). Any Red outcome measure makes the case Not Ready (MDM-D13 Section 3.3, rule 1). The status is not provisional: a change in the MDM-RSK-002 rating would not change it (MDM-D13 Section 4.1).

Measure	Value	Status
Outcome: control effectiveness (RM-07)	2 of 10 tests effective (20%)	Red
Outcome: residual risk profile (RM-08)	No High; 1 provisional	Amber
Outcome: remediation timeliness (RM-09)	None overdue	Green
Coverage: risks assessed (RM-01)	5 of 8 (63%)	Red
Coverage: controls tested (RM-02)	5 of 8 (63%)	Red
Coverage: standard requirements tested (RM-03)	21 of 35 (60%)	Red
Coverage: evidence accepted (RM-04)	62 of 75 (83%)	Amber
Coverage: findings fully traced (RM-05)	6 of 9 (67%)	Red
Coverage: open Risk Owner decisions (RM-06)	3 open, 1 with no date	Red

Source: MDM-D13 Section 4.2.

No control is rated Implemented. Three are Not Implemented, two Partial and three not rated, because they were not tested (MDM-D13 Section 4.3).

3.3 Why the Two Differ

The risk level follows the findings that remain open. No finding scores above 9, so every assessed risk sits at Medium (MDM-D12 Section 4). The readiness status asks whether the controls work as designed. Eight of ten tests found that they do not yet, and each of the five controls tested fell short in at least one test (MDM-D13 Sections 4.2–4.3).

The findings are moderate one by one, but they are many and spread across the tested scope. Medium risk does not mean ready, and Not Ready does not mean High risk. Both results also cover the tested scope only: three risks are not assessed and three controls are not tested.

4. Top Three Gaps

The three gaps are corporate data leaving managed control on iOS, requirements with no control or owner, and scope that has not been tested. Together they set the risk level and keep the case from Ready.

Each gap meets one of three criteria. It sets the highest current residual risk, it is the root cause behind other findings, or it blocks Ready even if every retest passes. The criteria use the existing ratings and add no new ones.

4.1 Corporate Data Can Leave Managed Control on iOS

Field	Detail
Criterion	Sets the highest current residual risk
What happens now	A noncompliant corporate iPhone still reaches OneDrive, because the required OneDrive app configuration was not deployed (MDM-FND-002, score 9). On personal iOS devices, the Share extension moves encrypted corporate files to personal apps. The files could not be opened there (MDM-FND-001, score 8).
What is required	Noncompliant corporate devices are blocked from corporate services, and corporate files stay in approved apps (MDM-D07 Section 4.4; MDM-D08; MDM-CTL-002).
Risk left open	MDM-RSK-002, corporate data leakage, at Medium (9), provisional. The Share extension exposure was accepted under D-02, so the risk stays at Medium (8) or above.
Response	MDM-REC-002 deploys the configuration. MDM-REC-001 records the iOS constraint. MDM-REC-011 confirms encryption in transit. All are retested by 14 February 2027.

Sources: MDM-D11 Section 4.1; MDM-D12 Sections 3–5.

4.2 Requirements with No Control or Owner

Field	Detail
Criterion	Root cause behind other findings
What happens now	Encryption, data removal, the BYOD notice and browser access work in the simulation. However, MDM-D05 has no control, owner or risk for them, because it was not updated when MDM-D07 added them (MDM-FND-009). Two failures already follow from this: the wipe of a lost device was never confirmed (MDM-FND-007), and BYOD activation records have no

Field	Detail
	retention period (MDM-FND-008).
What is required	Each MDM-D07 requirement has a control, an owner and a linked risk. Data removal is mapped to NCA ECC 2-6-3-3.
Risk left open	No one is accountable for keeping these capabilities working, so a failure could go unnoticed. The worst case is corporate data left on a lost device, under MDM-RSK-001 at Medium (6).
Response	MDM-REC-009 adds the four controls to MDM-D05, owned by the CISO and retested by Internal Audit by 14 February 2027. MDM-REC-007 and 008 fix the two failures.

Sources: MDM-D11 Section 4.2; MDM-D12 Sections 4–5.

4.3 Part of the Scope Is Untested

Field	Detail
Criterion	Blocks Ready even if every retest passes
What happens now	3 of 8 risks are not assessed, 3 of 8 controls are not tested, and 14 of 35 standard requirements are untested. One of them, MDM-STD-009, was also missing from the untested list in MDM-D10. The next test cycle has no date.
What is required	Every coverage measure at 100% before the case can be called Ready (MDM-D13 Section 3.3).
Risk left open	Exposure in the untested areas is unknown, so the Medium risk level may understate it. If every retest passes, the best status is Ready with Conditions.
Response	MDM-REC-010 tests MDM-CTL-004 by 14 February 2027, which brings risks assessed and controls tested to 6 of 8 (75%). The rest needs the next test cycle, which is the decision in Section 6.

Sources: MDM-D13 Sections 4.1, 4.2 and 4.5.

4.4 Other Findings

MDM-FND-003 to 006 and the open MFA confirmation (MDM-REC-012) are not among the three. Each finding scores 6, and each item has an owner and a retest by 14 February 2027 (MDM-D12 Sections 4–5). MDM-FND-003 concerns the broadest administrative account, so Internal Audit, not the CISO, validates its closure.

5. Immediate Action and Owners

Remediation starts with MDM-REC-002, the OneDrive configuration for corporate iOS devices. The IT Operations Manager owns it, and the GRC Analyst retests it by 14 February 2027. Two actions run alongside it, because they decide how far the risk level can be trusted and fix the root cause.

5.1 Start Now

Order	Action	Why Now	Owner	Retest
1	MDM-REC-002: deploy the OneDrive app configuration to corporate iOS devices, and check the other five approved apps for the same bypass	Highest-scored finding (9) and first in the remediation priority	IT Operations Manager	GRC Analyst, by 14 February 2027. Passes when a noncompliant corporate iPhone is blocked in all six apps
2	MDM-REC-011: provide the missing evidence and review the network path for encryption in transit	Decides whether MDM-RSK-002 stays provisional and whether D-04 takes effect	IT Operations Manager	GRC Analyst, by 14 February 2027. Passes when the evidence is accepted and the review is recorded
3	MDM-REC-009: add controls for encryption, data removal, the BYOD notice and browser access to MDM-D05, each with an owner and a linked risk	Fixes the root cause behind MDM-FND-007 and 008; runs alongside the others	CISO; the GRC Analyst prepares the draft	Internal Audit, by 14 February 2027, because GRC prepares the draft

Sources: MDM-D11 Sections 5.1 and 5.3; MDM-D12 Section 5.

MDM-REC-007 also asks for the wipe status of the lost device to be confirmed now. It is a single check, so it does not wait for its place in the order.

The other recommendations follow the MDM-D11 priority: MDM-REC-001 (8), then the findings scored 6, then MDM-REC-008 (Low). All are retested by 14 February 2027, except MDM-REC-008 by 15 May 2027 (MDM-D12 Section 5).

5.2 Accountability

Role	Accountable For
IT Operations Manager (Control Owner)	Delivers nine of the twelve recommendations, and reports each one complete so it can be

Role	Accountable For
	retested
CISO	Owns MDM-REC-003, 009 and 012. Approves the monthly dashboard and this report, and raises open items with the Business Owner
Business Owner (Risk Owner)	Decides treatment and accepts residual risk, including D-01 to D-04
GRC Analyst	Retests the recommendations, except where GRC prepared the work. Prepares the dashboard and this report
Internal Audit	Retests MDM-REC-003 and 009, so no one checks their own work

Sources: MDM-D11 Section 5; MDM-D12 Sections 2.3, 3 and 5; MDM-D13 Section 5.

A recommendation that passes its due date is escalated to the Risk Owner within five working days (MDM-D13 Section 5.2). As at 16 November 2026, none is overdue.

6. Decisions Required from Management

Management is asked to approve the next test cycle and set its date, and to require a date for the IT Operations assessment behind D-01. Both items have no date at working level, and both are needed before the case can be called Ready.

6.1 Decisions Required

Decision	Why It Is Needed	If Not Decided
1. Approve the next test cycle and set its date. It covers MDM-CTL-006, MDM-CTL-008 and the untested MDM-D07 requirements, starting with Section 5.2 (permissions)	The case cannot reach Ready while any part of the scope is untested. The retests due by 14 February 2027 cannot close this gap	The best status the case can reach is Ready with Conditions. MDM-RSK-006 and 008 stay not assessed, so the risk level stays incomplete
2. Require a date for the IT Operations assessment behind D-01	D-01 is the only Risk Owner decision with no date. Until it is made, the MDM-RSK-003 target stays open	Open Risk Owner decisions (RM-06) stay Red. The access window after a device loses compliance stays undecided

Sources: MDM-D12 Sections 3–4; MDM-D13 Sections 3.3, 4.4 and 4.5.

If either item still has no date by the dashboard issue of 16 January 2027, the CISO raises it with the Business Owner (MDM-D13 Section 5.2). A decision from management now avoids waiting for that escalation.

6.2 Decisions Already Taken

The Business Owner, as Risk Owner, decided the four items raised in MDM-D11 on 16 November 2026. They are listed for information and need no further decision from management. No finding requires mandatory management review under the MDM-D11 rules.

Item	Decision	Status
D-01: access window after a device loses compliance (MDM-RSK-003)	IT Operations assesses ways to shorten the window before the Business Owner decides	Pending; no date for the assessment (decision 2 above)
D-02: iOS Share extension exposure (MDM-RSK-002)	Accepted, with encryption as the protection that applies	In effect, on condition that shared files cannot be opened outside managed apps
D-03: Android immediate lock (MDM-RSK-001)	No decision until MDM-REC-005 measures the unlock window	Not needed yet
D-04: BYOD without MDM enrollment, a deviation from SAMA CSF 3.3.10 consideration 4(e) (MDM-RSK-002)	Accepted on condition, with app-level controls as the alternative. The CISO advised in favour	Not yet in effect. It takes effect only when MDM-REC-011 confirms encryption in transit

Source: MDM-D12 Section 3.

Management should note D-04 in particular, because it accepts a deviation from a regulatory framework. If encryption in transit is not confirmed, it returns to the Business Owner (MDM-D12 Section 6).

7. Outlook

If every retest due by 14 February 2027 passes, the case is expected to reach Ready with Conditions. This is a projection, not a result. Ready also needs the next test cycle, and the risk level would stay Medium.

7.1 What the Retests Can Change

Date	What Is Checked	Expected Effect If It Passes
14 February 2027	Retests of MDM-REC-001, 002, 004 to 007 and 009 to 012, and the first quarterly review under MDM-REC-003	Control effectiveness reaches 8 of 10 (80%, Amber), and the status becomes Ready with Conditions. MDM-REC-010 brings risks assessed and controls tested to 6 of 8 (75%). D-03 and D-

Date	What Is Checked	Expected Effect If It Passes
		04 are settled
15 May 2027	Retest of MDM-REC-008	One more test counts as effective
After the second quarterly review	Closure of MDM-REC-003, validated by Internal Audit	MDM-CTL-005 can reach Implemented
Not set	IT Operations assessment for D-01	The MDM-RSK-003 target can be reset (decision 2 in Section 6)
Not set	Next test cycle	Needed for any coverage measure to reach 100%, and so for Ready (decision 1 in Section 6)

Sources: MDM-D13 Sections 4.1, 4.2 and 4.4.

Even if every retest passes, the risk level stays Medium. MDM-RSK-002 cannot fall below Medium (8) while D-02 stands, and the MDM-RSK-003 target is Medium (6) until D-01 is decided. MDM-RSK-001, 005 and 007 are expected to reach Low (3) (MDM-D12 Section 4).

7.2 What Would Raise the Risk Level

Five of the six re-rating triggers in MDM-D12 could raise a rating or reopen a decision. The sixth, the D-01 decision, only resets a target. The first event below would return the risk level to High.

Event	Effect
A shared iOS file is shown to be readable outside managed apps	MDM-FND-001 rises to High (12). MDM-RSK-002 returns to High (12), and D-02 returns to the Business Owner
Encryption in transit is not confirmed, or the network path review finds an issue	D-04 does not take effect and returns to the Business Owner. A finding is raised against MDM-RSK-002
The Android unlock window exceeds one minute on any approved model	MDM-FND-005 is re-rated, and D-03 goes to the Business Owner for that model
Enterprise user MFA coverage is incomplete	A finding is raised and rated
A retest fails	The finding stays open and is re-rated. Its due date does not change

Source: MDM-D12 Section 6.

Each event is reported to the Risk Owner within five working days. A worse overall status is escalated to the CISO and the Business Owner in the same time (MDM-D13 Section 5.2).

7.3 Next Report

The next report follows the retests due by 14 February 2027. It draws on the dashboard snapshot issued within five working days after that date (MDM-D13 Section 5.1). It will show the actual retest results in place of the projection above.

8. Basis and Limitations

This report rests on MDM-D11 to MDM-D13 as at 16 November 2026. It covers the tested scope only, and all values are simulated.

8.1 Basis

Source	Used For	Sections
MDM-D02 Stakeholder and RACI Matrix	Who prepares and approves readiness conclusions	1
MDM-D04 Risk Assessment Methodology and Risk Register	Risk titles	3.1
MDM-D11 Findings and Remediation Register	Findings, gaps, recommendations, owners and remediation priority	2, 4, 5
MDM-D12 Risk Treatment and Retesting Record	Residual risk, Risk Owner decisions, retest plan and re-rating triggers	2 to 7
MDM-D13 GRC Workspace and Readiness Dashboard	Readiness measures and status, control readiness, milestones, reporting and escalation	2, 3, 6, 7

8.2 Assumptions

ID	Assumption
AS-01	MDM-D11 to MDM-D13 are current as at 16 November 2026. This report holds no value they do not hold.
AS-02	The retest dates in MDM-D12 Section 5 hold. The projections in Section 7 assume every retest passes.
AS-03	The roles in Section 5.2 exist as described in MDM-D02 and MDM-D12, including the Business Owner and Internal Audit.

8.3 Limitations

ID	Limitation
LM-01	No tenant was configured. All values, dates and decisions are simulated.
LM-02	The risk level and the readiness status cover the tested scope only. Three risks are not assessed and three controls are not tested (Section 4.3).
LM-03	The MDM-RSK-002 rating is provisional until MDM-REC-011 is retested.
LM-04	Projections in Section 7 are expectations, not results. They hold only after passed retests.
LM-05	The risk scales do not score regulatory impact. Regulatory exposure, such as under NCA ECC or the D-04 deviation from SAMA CSF, is noted but not rated (MDM-D11 LM-02).
LM-06	This report summarises. The test steps and evidence behind each result are in MDM-D09 to MDM-D11.